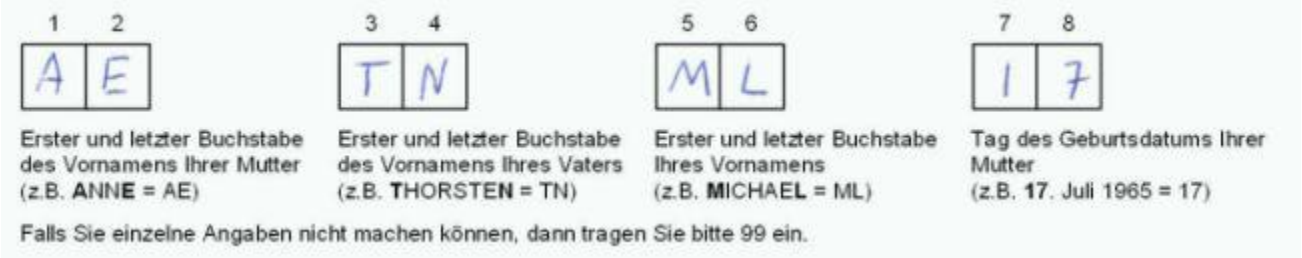
Data Science: Datenschutz

Dr. Konrad Völkel, Sommersemester 2026

Konkrete Lösungen für den Datenschutz

Heinrich Heine
Universität Düsseldorf

Bei Mehrfachbefragungen / Längsschnittuntersuchungen möchte man die einzelnen Antworten einer Person zusammenfassen können, ohne sie der Person zuordnen zu können.



1	2	3	4	5	6	7	8
A	E	T	N	M	L	1	7

Erster und letzter Buchstabe des Vornamens Ihrer Mutter (z.B. **ANNE** = AE)

Erster und letzter Buchstabe des Vornamens Ihres Vaters (z.B. **THORSTEN** = TN)

Erster und letzter Buchstabe Ihres Vornamens (z.B. **MICHAEL** = ML)

Tag des Geburtsdatums Ihrer Mutter (z.B. **17**. Juli 1965 = 17)

Falls Sie einzelne Angaben nicht machen können, dann tragen Sie bitte 99 ein.

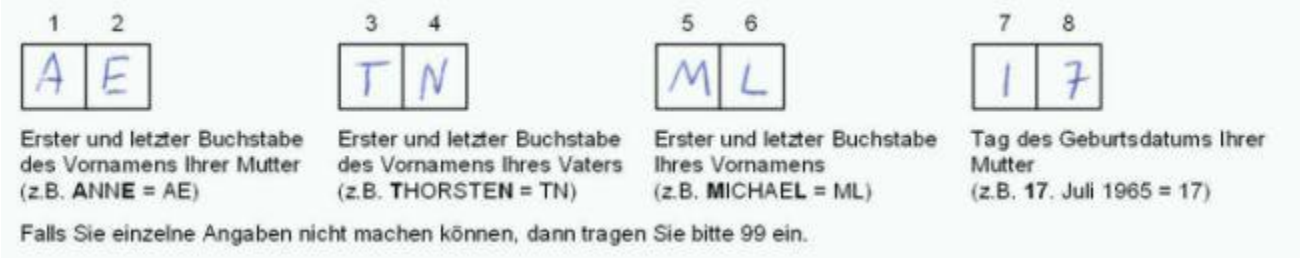
Aber: das sind so schon jede Menge private Informationen.
→ **Wie viele bit?**

Konkrete Lösungen für den Datenschutz

Heinrich Heine
Universität Düsseldorf

→ Hash-Funktionen retten den Tag:

Bei Mehrfachbefragungen / Längsschnittuntersuchungen möchte man die einzelnen Antworten einer Person zusammenfassen können, ohne sie der Person zuordnen zu können.



1	2	3	4	5	6	7	8
A	E	T	N	M	L	1	7

Erster und letzter Buchstabe des Vornamens Ihrer Mutter (z.B. **ANNE** = AE)	Erster und letzter Buchstabe des Vornamens Ihres Vaters (z.B. **THORSTEN** = TN)	Erster und letzter Buchstabe Ihres Vornamens (z.B. **MICHAEL** = ML)	Tag des Geburtsdatums Ihrer Mutter (z.B. **17**. Juli 1965 = 17)

Falls Sie einzelne Angaben nicht machen können, dann tragen Sie bitte 99 ein.

Speichert man den Hash dieses Codes, ist alles gut. Insbesondere: legal. 😇

Siehe auch: Persönliche Codes bei Längsschnittuntersuchungen III: fehlertolerante Zuordnung unverschlüsselter und verschlüsselter selbstgenerierter Codes im empirischen Test, Andreas Pöge, Methoden, Daten, Analysen (mda), 5 (2011) 1, p. 109-134, https://nbn-resolving.org/urn:nbn:de:0168-ssoar-255044

Daten-Recht?

Was ist der Rahmen?



“Humanoid android raising eyebrow, detailed, Matisse”

Datenrecht: EU-Datenstrategie

Heinrich Heine
Universität Düsseldorf

“Die [europäische] Kommission hat schon seit 2014 eine Reihe von Maßnahmen ergriffen. Mit der Datenschutz-Grundverordnung (DSGVO) hat die EU einen soliden Rahmen für Vertrauen im digitalen Umfeld geschaffen.”

--- 19.2.2020, “Eine europäische Datenstrategie”, MITTEILUNG DER KOMMISSION AN DAS EUROPÄISCHE PARLAMENT, DEN RAT, DEN EUROPÄISCHEN WIRTSCHAFTS- UND SOZIALAUSSCHUSS UND DEN AUSSCHUSS DER REGIONEN

Datenrecht: europäischer AI Act

Heinrich Heine
Universität Düsseldorf

“Damit die Sicherheit und die Einhaltung bestehender Rechtsvorschriften zum Schutz der Grundrechte über den gesamten Lebenszyklus von KI-Systemen hinweg gewahrt bleiben, werden Anbietern und Nutzern dieser Systeme berechenbare, verhältnismäßige und klare Pflichten auferlegt.”

--- 21.4.2021, Vorschlag “Gesetz über künstliche Intelligenz” (Vorschlag für eine Verordnung des europ. Parlaments und des Rates zur Festlegung harmonisierter Vorschriften für künstliche Intelligenz), europ. Kommission

Datenrecht: EU-Digitale-Märkte-Gesetz

Heinrich Heine
Universität Düsseldorf

“WhatsApp, iMessage, Signal – im Moment sind alle Chatdienste voneinander getrennt. Die Europäische Union will nun festlegen, dass Messenger auch miteinander kommunizieren müssen.”

--- 25.3.2022, Bayerischer Rundfunk über den EU Digital Markets Act

Datenrecht: EU-Datenstrategie

Heinrich Heine Universität Düsseldorf

aus: Der Data Act, Vera Demary, Institut der dt. Wirtschaft Köln e.V., Mai 2022



Was zuvor geschah

mit Blick auf die DSGVO



“Jungle disco, Rick Astley at the microphone”

Vorgänger der DSGVO in Deutschland

Heinrich Heine Universität Düsseldorf

Bundesverfassungsgericht zum Volkszählungsgesetz vom 27. April 1983 (S.46f)

„Mit dem Recht auf informationelle Selbstbestimmung wären eine Gesellschaftsordnung und eine diese ermöglichende Rechtsordnung nicht vereinbar, **in der Bürger nicht mehr wissen können, wer was wann und bei welcher Gelegenheit über sie weiß**. [...]

Freie Entfaltung der Persönlichkeit setzt unter den modernen Bedingungen der Datenverarbeitung den **Schutz** des Einzelnen **gegen unbegrenzte** Erhebung, Speicherung, Verwendung und Weitergabe seiner persönlichen Daten voraus."

Vorgänger der DSGVO in Deutschland

Heinrich Heine
Universität Düsseldorf

Bundesdatenschutzgesetz von 1990

> „Zweck dieses Gesetzes ist es, den Einzelnen davor zu schützen, dass er durch den Umgang mit seinen personenbezogenen Daten in seinem Persönlichkeitsrecht beeinträchtigt wird.“

Nicht in den Geltungsbereich fielen Daten über juristische Personen (GmbH, AG usw.).

Besonders geschützt wurden **Daten über ethnische Herkunft, die politische Meinung, religiöse oder philosophische Überzeugungen, die Gewerkschaftszugehörigkeit, die Gesundheit und das Sexualleben**.
Dafür zuständig war der Beauftragte für den Datenschutz, den eine Institution bestellen musste.

Vorgänger der DSGVO in der EU

Heinrich Heine Universität Düsseldorf

Richtlinie 95/46/EG des Europäischen Parlaments und des Rates vom 24. 10. 1995

zum Schutz natürlicher Personen bei der Verarbeitung personenbezogener Daten und zum freien Datenverkehr -- Aufgehoben durch Verordnung (EU) 2016/679 (die DSGVO)

> KAPITEL II ALLGEMEINE BEDINGUNGEN FÜR DIE RECHTMÄSSIGKEIT DER VERARBEITUNG PERSONENBEZOGENER DATEN - **Artikel 5**
>
> Die Mitgliedstaaten bestimmen nach Maßgabe dieses Kapitels die Voraussetzungen näher, unter denen die Verarbeitung personenbezogener Daten rechtmäßig ist.

ABSCHNITT II GRUNDSÄTZE IN BEZUG AUF DIE ZULÄSSIGKEIT DER VERARBEITUNG VON DATEN -- Artikel 7

Die Mitgliedstaaten sehen vor, daß die Verarbeitung personenbezogener Daten lediglich erfolgen darf, wenn *eine* der folgenden Voraussetzungen erfüllt ist:

a) Die betroffene Person hat *ohne jeden Zweifel ihre Einwilligung gegeben*;

b) die Verarbeitung ist *erforderlich für die Erfüllung eines Vertrags, dessen Vertragspartei die betroffene Person ist*, oder für die Durchführung vorvertraglicher Maßnahmen, die auf Antrag der betroffenen Person erfolgen;

c) die Verarbeitung ist *für die Erfüllung einer rechtlichen Verpflichtung erforderlich*, der der für die Verarbeitung Verantwortliche unterliegt;

d) die Verarbeitung ist *erforderlich für die Wahrung lebenswichtiger Interessen der betroffenen Person*;

e) die Verarbeitung ist *erforderlich für die Wahrnehmung einer Aufgabe, die im öffentlichen Interesse liegt* oder in Ausübung öffentlicher Gewalt erfolgt und dem für die Verarbeitung Verantwortlichen oder dem Dritten, dem die Daten übermittelt werden, übertragen wurde;

f) die Verarbeitung ist *erforderlich zur Verwirklichung des berechtigten Interesses*, das von dem für die Verarbeitung Verantwortlichen oder von dem bzw. den Dritten wahrgenommen wird, denen die Daten übermittelt werden, sofern nicht das Interesse oder die Grundrechte und Grundfreiheiten der betroffenen Person, die gemäß Artikel 1 Absatz 1 geschützt sind, überwiesen.

ABSCHNITT III BESONDERE KATEGORIEN DER VERARBEITUNG -- Artikel 8

Verarbeitung *besonderer Kategorien* personenbezogener Daten

(1) Die Mitgliedstaaten untersagen die Verarbeitung personenbezogener Daten, aus denen die *rassische und ethnische Herkunft*, *politische Meinungen*, *religiöse oder philosophische Überzeugungen* oder die *Gewerkschaftszugehörigkeit* hervorgehen, sowie von Daten über *Gesundheit* oder *Sexualleben*.

ABSCHNITT V AUSKUNFTSRECHT DER BETROFFENEN PERSON -- Artikel 12 - Auskunftsrecht

Die Mitgliedstaaten garantieren jeder betroffenen Person das Recht, vom für die Verarbeitung Verantwortlichen folgendes zu erhalten:

a) frei und ungehindert in angemessenen Abständen ohne unzumutbare Verzögerung oder übermäßige Kosten

- die Bestätigung, daß es Verarbeitungen sie betreffender Daten gibt oder nicht gibt, sowie zumindest Informationen über die Zweckbestimmungen dieser Verarbeitungen, die Kategorien der Daten, die Gegenstand der Verarbeitung sind,
  und die Empfänger oder Kategorien der Empfänger, an die die Daten übermittelt werden;
- eine Mitteilung in verständlicher Form über die Daten, die Gegenstand der Verarbeitung sind, sowie die verfügbaren Informationen über die Herkunft der Daten;
- Auskunft über den logischen Aufbau der automatisierten Verarbeitung der sie betreffenden Daten, zumindest im Fall automatisierter Entscheidungen im Sinne von Artikel 15 Absatz 1;

b) je nach Fall die Berichtigung, Löschung oder Sperrung von Daten, deren Verarbeitung nicht den Bestimmungen dieser Richtlinie entspricht, insbesondere wenn diese Daten unvollständig oder unrichtig sind;

c) die Gewähr, daß jede Berichtigung, Löschung oder Sperrung, die entsprechend Buchstabe b) durchgeführt wurde, den Dritten, denen die Daten übermittelt wurden, mitgeteilt wird, sofern sich dies nicht als unmöglich erweist oder kein unverhältnismäßiger Aufwand damit verbunden ist.

KAPITEL III RECHTSBEHELFE, HAFTUNG UND SANKTIONEN -- Artikel 23 - Haftung

(1) Die Mitgliedstaaten sehen vor, daß *jede Person*, der wegen einer rechtswidrigen Verarbeitung oder jeder anderen mit den einzelstaatlichen Vorschriften zur Umsetzung dieser Richtlinie nicht zu vereinbarenden Handlung ein Schaden entsteht, *das Recht hat*, von dem für die Verarbeitung Verantwortlichen *Schadenersatz zu verlangen*.

(2) Der für die Verarbeitung Verantwortliche kann teilweise oder vollständig von seiner Haftung befreit werden, wenn er nachweist, daß der Umstand, durch den der Schaden eingetreten ist, ihm nicht zur Last gelegt werden kann.

KAPITEL IV ÜBERMITTLUNG PERSONENBEZOGENER DATEN IN DRITTLÄNDER -- Artikel 25

Grundsätze

(1) Die Mitgliedstaaten sehen vor, *daß die Übermittlung personenbezogener Daten*, die Gegenstand einer Verarbeitung sind oder nach der Übermittlung verarbeitet werden sollen, in ein Drittland vorbehaltlich der Beachtung der aufgrund der anderen Bestimmungen dieser Richtlinie erlassenen einzelstaatlichen Vorschriften *zulässig ist, wenn dieses Drittland ein angemessenes Schutzniveau gewährleistet*.

Vorgänger der DSGVO auf europäischer Ebene ‘95

Richtlinie 95/46/EG des Europäischen Parlaments und des Rates vom 24. Oktober 1995

Nochmal der Überblick:

Kap. 1 Allgemeine Bestimmungen (Art. 1-4, Gegenstand, Begriffsbestimmungen, etc.)
Kap. 2 **Allgemeine Bedingungen für die Rechtmäßigkeit der Verarbeitung personenbezogener Daten** (Art. 5-21)
Kap. 3 Rechtsbehelfe Haftung und Sanktionen (Art. 22,**23**,24)
Kap. 4 Übermittlung personenbezogener Daten in Drittländer (Art. **25**,26)
Kap. 5 Verhaltensregeln (Art. 27)
Kap. 6 Kontrollstelle und Gruppe für den Schutz von Personen bei der Verarbeitung personenbezogener Daten (Art. 28,29,30)
Kap. 7 Gemeinschaftliche Durchführungsmassnahmen (Art. 31)
Schlussbestimmungen (Art. 32,33,34)

Vorgänger der DSGVO auf europäischer Ebene ‘97

Richtlinie 97/66/EG des Europäischen Parlaments und des Rates vom 15. Dezember 1997 über die Verarbeitung personenbezogener Daten und den Schutz der Privatsphäre im Bereich der Telekommunikation -- abgelöst durch 2002/58/EG

z.B. Artikel 12 Unerbetene Anrufe

(1) Die Verwendung von Kommunikation mit Automaten als Gesprächspartner (Voice-Mail-System) oder Fernkopien (Telefax) für die Zwecke des Direktmarketings darf **nur bei vorheriger Einwilligung** der Teilnehmer gestattet werden.

Vorgänger der DSGVO auf europäischer Ebene ‘00

Richtlinie 2000/31/EG des Europäischen Parlaments und des Rates vom 8. Juni 2000 über bestimmte rechtliche Aspekte der Dienste der Informationsgesellschaft, insbesondere des elektronischen Geschäftsverkehrs, im Binnenmarkt ("Richtlinie über den elektronischen Geschäftsverkehr") -- abgelöst durch 2002/58/EG

(14) Der Schutz natürlicher Personen bei der Verarbeitung personenbezogener Daten ist ausschließlich Gegenstand der *Richtlinie 95/46/EG des Europäischen Parlaments und des Rates vom 24. Oktober 1995 zum Schutz natürlicher Personen bei der Verarbeitung personenbezogener Daten und zum freien Datenverkehr* und der *Richtlinie 97/66/EG des Europäischen Parlaments und des Rates vom 15. Dezember 1997 über die Verarbeitung personenbezogener Daten und den Schutz der Privatsphäre im Bereich der Telekommunikation*, beide Richtlinien sind uneingeschränkt auf die Dienste der Informationsgesellschaft anwendbar

Vorgänger der DSGVO auf europäischer Ebene ‘02

Heinrich Heine Universität Düsseldorf

Richtlinie 2002/58/EG des Europäischen Parlaments und des Rates vom 12. Juli 2002 über die Verarbeitung personenbezogener Daten und den Schutz der Privatsphäre in der elektronischen Kommunikation (Datenschutzrichtlinie für elektronische Kommunikation) -- löst 2000/31/EG ab -- geändert in Richtlinie 2009/136/EG

z.B. (66) *Es ist denkbar, dass Dritte* aus einer Reihe von Gründen *Informationen auf der Endeinrichtung eines Nutzers speichern* oder auf bereits gespeicherte Informationen zugreifen wollen, die von legitimen Gründen (wie manchen Arten von *Cookies*) bis hin zum unberechtigten Eindringen in die Privatsphäre (z. B. über Spähsoftware oder Viren) reichen. ***Daher ist es von größter Wichtigkeit, dass den Nutzern eine klare und verständliche Information bereitgestellt wird***, wenn sie irgendeine Tätigkeit ausführen, die zu einer solchen Speicherung oder einem solchen Zugriff führen könnte. *Die Methoden der Information* und die Einräumung des Rechts, diese abzulehnen, *sollten so benutzerfreundlich wie möglich* gestaltet werden. *Ausnahmen* von der Informationspflicht und der Einräumung des Rechts auf Ablehnung sollten auf jene Situationen *beschränkt* sein, in denen die technische Speicherung oder der Zugriff *unverzichtbar* sind, um die Nutzung eines vom Teilnehmer oder Nutzer ausdrücklich angeforderten Dienstes zu ermöglichen.

DSGVO

== GDPR



“The cookie you don’t want to accept in the emoji browser”

Anwendungsbereich der DSGVO

Art.2 (1)

Diese Verordnung gilt für

- die ganz oder
  teilweise automatisierte Verarbeitung personenbezogener Daten sowie
- für die nichtautomatisierte Verarbeitung personenbezogener Daten,
  die in einem Dateisystem gespeichert sind oder gespeichert werden
  sollen.

Also:
(teil)automatisch oder (bald) im Dateisystem gespeicherte personenbezogene Daten

Privacy by Design

Heinrich Heine
Universität Düsseldorf

Die Grundsätze des Datenschutzes müssen bereits vor Beginn der technischen Planung in die Konzeptionierung von Verarbeitungsvorgängen integriert werden.

1. Was technisch unmöglich gemacht wird, muss nicht mehr überwacht werden
2. Funktionstrennung der Geschäftsabläufe; frühestmögliche Anonymisierung
3. Datenschutzfreundliche Architektur, physisch wie elektronisch

Privacy by Default

Heinrich Heine
Universität Düsseldorf

Spezialfall von “Privacy by Design”

Systeme müssen Voreinstellungen haben, die möglichst datenschutzfreundlich sind.

Problem:
Benutzer geben Datenschutzwunsch an, verhalten sich aber gegenteilig.

Vermutlich aus Faulheit, Unkenntnis oder aufgrund einer intuitiven Abwägung der Vor- und Nachteile.

Beispiel: Nutzung von Facebook, Akzeptieren von Cookies.
Privacy by Default soll dieses Problem lösen.

Datensparsamkeit

Heinrich Heine
Universität Düsseldorf

(zweckgebundene) Datenminimierung, Begrenzung der verarbeiteten Daten.
Auch: Datenvermeidung.

Beispiel: Bei einem Online-Einkauf soll das Alter angegeben werden.

Als Grund wird die zielgruppenspezifische Werbung angegeben.

Da dieses nicht für das Anliegen des Kunden erforderlich ist,
muss es möglich gemacht werden, die Altersangabe zu verweigern.

Auf diese Möglichkeit muss hingewiesen werden und
die Voreinstellung muss sein, dass das Alter nicht angegeben wird!

DSGVO Artikel 5

Heinrich Heine Universität Düsseldorf

Grundsätze für die Verarbeitung personenbezogener Daten:

1. **Rechtmäßigkeit**, Verarbeitung nach Treu und Glauben, **Transparenz**
2. **Zweckbindung** (Verarbeitung nur für festgelegte, eindeutige und legitime Zwecke)
3. **Datenminimierung** („dem Zweck angemessen und erheblich sowie auf das […] notwendige Maß beschränkt“)
4. **Richtigkeit** („es sind alle angemessenen Maßnahmen zu treffen, damit [unrichtige] personenbezogene Daten unverzüglich gelöscht oder berichtigt werden“)
5. **Speicherbegrenzung** (Daten müssen „in einer Form gespeichert werden, die die Identifizierung der betroffenen Personen nur so lange ermöglicht, wie es […] erforderlich ist“)
6. **Integrität** und **Vertraulichkeit** („angemessene Sicherheit der personenbezogenen Daten […], einschließlich Schutz vor unbefugter oder unrechtmäßiger Verarbeitung und vor unbeabsichtigtem Verlust, unbeabsichtigter Zerstörung oder unbeabsichtigter Schädigung“)

Strafen der DSGVO

bei Verletzung der Regeln



“A bunch of devices fighting against a single evil device”

DSGVO Artikel 83

Heinrich Heine Universität Düsseldorf

Allgemeine Bedingungen für die Verhängung von **Geldbußen**

(1) Jede Aufsichtsbehörde stellt sicher, dass die Verhängung von Geldbußen gemäß diesem Artikel für Verstöße gegen diese Verordnung [...] in jedem Einzelfall **wirksam**, **verhältnismäßig** und **abschreckend** ist.

(2) Geldbußen werden je nach den Umständen des Einzelfalls **zusätzlich zu oder anstelle von** Maßnahmen nach **Artikel 58 Absatz 2 Buchstaben a bis h und j** verhängt. [...]

(3) [...]

(4) Bei Verstößen gegen die folgenden Bestimmungen werden im Einklang mit Absatz 2 Geldbußen von bis zu **10 000 000 EUR** oder im Fall eines Unternehmens von **bis zu 2 % seines gesamten weltweit erzielten Jahresumsatzes** des vorangegangenen Geschäftsjahrs verhängt, je nachdem, welcher der Beträge höher ist: [...]

(5) [...] Geldbußen von bis zu 20 000 000 EUR oder im Fall eines Unternehmens von bis zu 4 % seines gesamten weltweit erzielten Jahresumsatzes des vorangegangenen Geschäftsjahrs [...]

(6) Bei Nichtbefolgung einer Anweisung der Aufsichtsbehörde [...] 20 000 000 EUR [...] 4 % [...].

DSGVO Artikel 58 (2)

Heinrich Heine
Universität Düsseldorf

Jede Aufsichtsbehörde verfügt über sämtliche folgenden **Abhilfebefugnisse**, die es ihr gestatten,

a) einen Verantwortlichen oder einen Auftragsverarbeiter zu warnen,
dass beabsichtigte Verarbeitungsvorgänge voraussichtlich gegen diese Verordnung verstoßen,

b) einen Verantwortlichen oder einen Auftragsverarbeiter zu verwarnen,
wenn er mit Verarbeitungsvorgängen gegen diese Verordnung verstoßen hat,

c) den Verantwortlichen oder den Auftragsverarbeiter anzuweisen,
den Anträgen der betroffenen Person auf Ausübung der ihr nach dieser Verordnung zustehenden Rechte zu entsprechen,

d) den Verantwortlichen oder den Auftragsverarbeiter anzuweisen,
Verarbeitungsvorgänge gegebenenfalls auf bestimmte Weise und
innerhalb eines bestimmten Zeitraums in Einklang mit dieser Verordnung zu bringen,

e) **den Verantwortlichen anzuweisen,**
die von einer Verletzung des Schutzes personenbezogener Daten betroffene Person entsprechend zu benachrichtigen,

f) **eine vorübergehende oder endgültige Beschränkung der Verarbeitung, einschließlich eines Verbots, zu verhängen,**

g) die Berichtigung oder Löschung von personenbezogenen Daten oder die Einschränkung der Verarbeitung gemäß den Artikeln 16, 17 und 18 und
die Unterrichtung der Empfänger, an die diese personenbezogenen Daten gemäß Artikel 17 Absatz 2 und Artikel 19 offengelegt wurden,
über solche Maßnahmen anzuordnen,

h) eine Zertifizierung zu widerrufen oder die Zertifizierungsstelle anzuweisen, eine gemäß den Artikel 42 und 43 erteilte Zertifizierung zu widerrufen,
oder die Zertifizierungsstelle anzuweisen, keine Zertifizierung zu erteilen,
wenn die Voraussetzungen für die Zertifizierung nicht oder nicht mehr erfüllt werden,

i) eine Geldbuße gemäß Artikel 83 zu verhängen, zusätzlich zu oder anstelle von in diesem Absatz genannten Maßnahmen,
je nach den Umständen des Einzelfalls,

j) die Aussetzung der Übermittlung von Daten an einen Empfänger in einem Drittland oder an eine internationale Organisation anzuordnen.

DSGVO Artikel 40 - Verhaltensregeln (2)

Verbände und andere Vereinigungen, die Kategorien von Verantwortlichen oder Auftragsverarbeitern vertreten, **können Verhaltensregeln ausarbeiten** oder ändern oder erweitern, mit denen die Anwendung dieser Verordnung beispielsweise zu dem Folgenden präzisiert wird:

a) **faire** und **transparente** Verarbeitung;

b) die **berechtigten Interessen** des Verantwortlichen in bestimmten Zusammenhängen;

c) **Erhebung** personenbezogener Daten;

d) **Pseudonymisierung** personenbezogener Daten;

e) **Unterrichtung** der Öffentlichkeit und der betroffenen Personen;

f) **Ausübung der Rechte betroffener** Personen;

g) Unterrichtung und **Schutz von Kindern** und Art und Weise, in der die **Einwilligung** des Trägers **der elterlichen Verantwortung** für das Kind einzuholen ist;

h) die Maßnahmen und Verfahren gemäß den Artikeln 24 und 25 und die Maßnahmen für die Sicherheit der Verarbeitung gemäß Artikel 32;

i) die **Meldung von Verletzungen des Schutzes** personenbezogener Daten an Aufsichtsbehörden und die **Benachrichtigung der betroffenen Person** von solchen Verletzungen des Schutzes personenbezogener Daten;

j) die **Übermittlung** personenbezogener Daten **an Drittländer** oder an internationale Organisationen oder

k) **außergerichtliche Verfahren** und sonstige Streitbeilegungsverfahren zur Beilegung von Streitigkeiten zwischen Verantwortlichen und betroffenen Personen im Zusammenhang mit der Verarbeitung, unbeschadet der Rechte betroffener Personen gemäß den Artikeln 77 und 79.

DSGVO Artikel 83 - Geldbußen (2)

Heinrich Heine Universität Düsseldorf

Geldbußen werden je nach den Umständen des Einzelfalls zusätzlich zu oder anstelle von Maßnahmen nach **Artikel 58 Absatz 2** Buchstaben a bis h und j verhängt. **Bei der Entscheidung über die Verhängung einer Geldbuße und über deren Betrag wird in jedem Einzelfall Folgendes gebührend berücksichtigt**:

a) **Art, Schwere und Dauer** des Verstoßes unter Berücksichtigung der Art, des Umfangs oder des Zwecks der betreffenden Verarbeitung sowie der **Zahl der** von der Verarbeitung **betroffenen Personen** und des **Ausmaßes** des von ihnen erlittenen **Schadens**;

b) **Vorsätzlichkeit** oder **Fahrlässigkeit** des Verstoßes;

c) jegliche von dem Verantwortlichen oder dem Auftragsverarbeiter getroffenen **Maßnahmen zur Minderung** des den betroffenen Personen entstandenen Schadens;

d) **Grad der Verantwortung** des Verantwortlichen oder des Auftragsverarbeiters unter Berücksichtigung der von ihnen gemäß den Artikeln 25 und 32 getroffenen technischen und organisatorischen Maßnahmen;

e) etwaige einschlägige **frühere Verstöße** des Verantwortlichen oder des Auftragsverarbeiters;

f) Umfang der **Zusammenarbeit mit der Aufsichtsbehörde**, um dem Verstoß abzuhelfen und seine möglichen nachteiligen Auswirkungen zu mindern;

g) **Kategorien personenbezogener Daten**, die von dem Verstoß betroffen sind;

h) Art und Weise, wie der Verstoß der Aufsichtsbehörde bekannt wurde, insbesondere ob und gegebenenfalls in welchem Umfang der Verantwortliche oder der Auftragsverarbeiter den **Verstoß mitgeteilt** hat;

i) **Einhaltung der** nach **Artikel 58 Absatz 2** früher gegen den für den betreffenden Verantwortlichen oder Auftragsverarbeiter in Bezug auf denselben Gegenstand **angeordneten Maßnahmen**, wenn solche Maßnahmen angeordnet wurden;

j) **Einhaltung von** genehmigten **Verhaltensregeln** nach **Artikel 40** oder genehmigten **Zertifizierungsverfahren** nach Artikel 42 und

k) jegliche anderen erschwerenden oder mildernden Umstände im jeweiligen Fall, wie unmittelbar oder mittelbar durch den Verstoß **erlangte finanzielle Vorteile oder vermiedene Verluste**.

www.enforcementtracker.com

GDPR Enforcement Tracker

tracked by CMS law·tax·future

The CMS.Law GDPR Enforcement Tracker is an overview of fines and penalties which data protection authorities within the EU have imposed under the EU General Data Protection Regulation (GDPR, DSGVO). Our aim is to keep this list as up-to-date as possible. Since not all fines are made public, this list can of course never be complete, which is why we appreciate any indication of further GDPR fines and penalties. *Please note that we do not list any fines imposed under national / non-European laws, under non-data protection laws (e.g. competition laws / electronic communication laws) and under "old" pre-GDPR-laws.*

New features: "ETid" and "Direct URL"!
We have assigned a unique and permanent ID to each fine in our database, which makes it possible to precisely address fines, e.g. in publications. Once an "ETid" has been assigned to a fine, it remains the same, even if the fine is overturned or amended by courts at a later date, or if we add fines that were issued chronologically before. The "Direct URL" (click "+" or on a specific ETid to view details of a fine) can be used to share fines online, e.g. on Twitter or other media.

Show 10 entries

Search:

ETid	Country	Date of Decision	Fine [€]	Controller/Processor	Quoted Art.	Type	Source
ETid-891	ROMANIA	2021-11-1	5,000	S.P.E.E.H. Hidroelectrica S.A.	Art. 32 (1) b), (2) GDPR	Insufficient technical and organisational measures to ensure information security	link
ETid-890	ROMANIA	2021-11-1	1,000	IKEA ROMÂNIA SA	Art. 32 (1) b), (2) GDPR	Insufficient technical and organisational measures to ensure information security	link
ETid-889	SPAIN	2021-10-26	40,000	VODAFONE SERVICIOS, S.L.U.	Art. 6 (1) GDPR	Insufficient legal basis for data processing	link
ETid-888	SPAIN	2021-10-26	40,000	VODAFONE SERVICIOS, S.L.U.	Art. 6 (1) GDPR	Insufficient legal basis for data processing	link
ETid-887	SPAIN	2021-10-26	16,000	SERVICIOS LOGÍSTICOS MARTORELL SIGLO XXI, S.L.	Art. 35 GDPR	Non-compliance with general data processing principles	link
ETid-886	SPAIN	2021-10-26	64,000	Vodafone España, S.A.U.	Art. 6 (1) GDPR	Insufficient legal basis for data processing	link
ETid-885	SPAIN	2021-10-25	3,000	MERCEDES GERENCIA, S.L.	Art. 58 (1) GDPR	Insufficient cooperation with supervisory authority	link

	ETid	Country	Date of Decision	Fine [€]	Controller/Processor	Quoted Art.	Type	Source
	Filter Column	Filter Column		Filter Column	Filter Column		Filter Column	
⊖	ETid-405	GERMANY	2020-10-01	35,258,708	H&M Hennes & Mauritz Online Shop A.B. & Co. KG	Art. 5 GDPR, Art. 6 GDPR	Insufficient legal basis for data processing	link

Authority Data Protection Authority of Hamburg

Sector Employment

Summary The fashion company with seat in Hamburg operates a service center in Nuremberg. Here, according to the findings of the Hamburg data protection officer, since at least 2014 private life circumstances of some of the employees have been comprehensively recorded and this information stored on a network drive. For example, the company conducted a 'Welcome Back Talk' after employees returned to work after vacation or illness. The information that became known in this context - including information on the symptoms of illness and diagnoses of the employees - was recorded and stored. In addition, according to the Hamburg data protection authority, some supervisors also used the 'Flurfunk' [meaning to hear something through the grapevine] to acquire a broad knowledge of individual employees, for example about family problems and religious beliefs. The information stored on the network drive was accessible to up to 50 managers of the company and was used, among other things, to evaluate the work performance of the employees and to make employment decisions.The data collection became known due to a technical configuration error in October 2019, according to which the data stored on the network drive was accessible company-wide for several hours. After the violation became known, the management apologized to the employees and offered monetary compensation. In addition, also further protective measures were introduced together with the data protection authority. [Note: Concrete legal basis of the fine not yet published - we assume this will mainly be Art. 5 and 6 GDPR]

Direct URL https://www.enforcementtracker.com/ETid-405 (Copy:) | Short URL: https://etid.link/ETid-405

⊖	ETid-519	GERMANY	2021-01-08	10,400,000	notebooksbilliger.de	Art. 5 GDPR, Art. 6 GDPR	Insufficient legal basis for data processing	link

Authority Data Protection Authority of Niedersachsen

Sector Employment

Summary The DPA of Lower Saxony (LfD Niedersachsen) imposed a fine of EUR 10,4 million on the electronics retailer notebooksbilliger.de.The company had video-monitored its employees for at least two years without having a legal basis for doing so. Among others, the cameras covered workplaces, sales areas, warehouses and recreation areas. The company stated that the purpose of the installed video cameras was to prevent and investigate criminal acts and to track the movement of goods in the warehouses. However, to prevent theft, a company must first consider milder methods. Moreover, video surveillance to detect criminal acts is only permitted if there is a reasonable suspicion against specific persons. If this is the case, it may be permissible to monitor them with cameras for a limited period of time. At notebooksbilliger.de, however, the video surveillance was neither limited to a specific period nor to specific employees. In addition, the recordings were stored for 60 days in many cases, which was significantly longer than required. Customers of notebooksbilliger.de were also affected by the unlawful video surveillance, as some cameras were pointed at seating areas in the sales area. So far, the fine against notebooksbilliger.de is the highest fine that the LfD Niedersachen has issued under the GDPR.

Direct URL https://www.enforcementtracker.com/ETid-519 (Copy:) | Short URL: https://etid.link/ETid-519

⊖	ETid-306	GERMANY	2020-06-30	1,240,000	Allgemeine Ortskrankenkasse ('AOK') (health insurance company)	Art. 5 GDPR, Art. 6 GDPR, Art. 32 GDPR	Insufficient technical and organisational measures to ensure information security	link

Authority Data Protection Authority of Baden-Wuerttemberg

Sector Finance, Insurance and Consulting

Summary From 2015 to 2019, AOK Baden-Württemberg (insurance organization) organized competitions on various occasions and collected personal data of the participants, including their contact details and health insurance affiliation. The AOK also wanted to use this data for advertising purposes, provided the participants had given their consent. With the help of technical and organizational measures, including internal guidelines and data protection training, the AOK wanted to ensure that only data of those contest participants who had previously given their effective consent would be used for advertising purposes. However, the measures defined by the AOK did not meet the legal requirements. As a result, the personal data of more than 500 lottery participants were used for advertising purposes without their consent. Immediately after this became known, the AOK Baden-Württemberg stopped all marketing measures in order to thoroughly examine all processes.

Direct URL https://www.enforcementtracker.com/ETid-306 (Copy:) | Short URL: https://etid.link/ETid-306

⊕	ETid-846	GERMANY	2021-09-24	900,000	Vattenfall Europe Sales GmbH	Art. 12 GDPR, Art. 13 GDPR	Insufficient data processing agreement	link
⊕	ETid-128	GERMANY	2020-11-11	900,000	Telecoms provider (1&1 Telecom GmbH)	Art. 32 GDPR	Insufficient technical and organisational measures to ensure information security	link

Einzelfälle

2019-08-05 200 € Private person (YouTube-Channel)

The private person used a **dashcam to make recordings of public road traffic and then published** them on YouTube as a compilation.

2019 800 € Police Officer

A police officer **used a witness's personal data** to contact her **personally**.

2019-02-05 2500 € Private person

sent several e-mails between July and September 2018, in which he used personal e-mail addresses visible to all recipients, **from which each recipient could read countless other recipients**. The man was accused of ten offences between mid-July and the end of July 2018. According to the authority's letter, between 131 and 153 personal mail addresses were identifiable in his mailing list.

Einzelfälle 2

2018-11-21 20.000 € Knuddels.de

After **a hacker attack** in July personal data of approx. 330.000 users, including passwords and email addresses had been revealed.

2020-12-15 450.000 € Twitter International Company

The Irish DPA (DPC) fined Twitter [...] for failing to notify the DPA in a timely manner of a data breach and not adequately documenting that breach. [...] A programming bug in Twitter's Android app resulted in some private posts being visible to the public. [...] Twitter's legal team became aware of the error on January 2nd, 2019, and it was not until January 8th that the company informed the DPC.
Consequently, **the company failed to inform the DPC within the 72-hour period** [...].

Einzelfälle 3

2021-03-15 1000 € School

The Belgian DPA (APD) fined a school EUR 1,000. The controller had conducted a survey on student well-being via a smartschooling system. The DPA states that the controller **did not obtain the consent of the parents** of the minor students and **violated the principle of data minimization**. The original fine of EUR 2,000 was reduced to EUR 1,000 after the controller appealed the APD's decision.

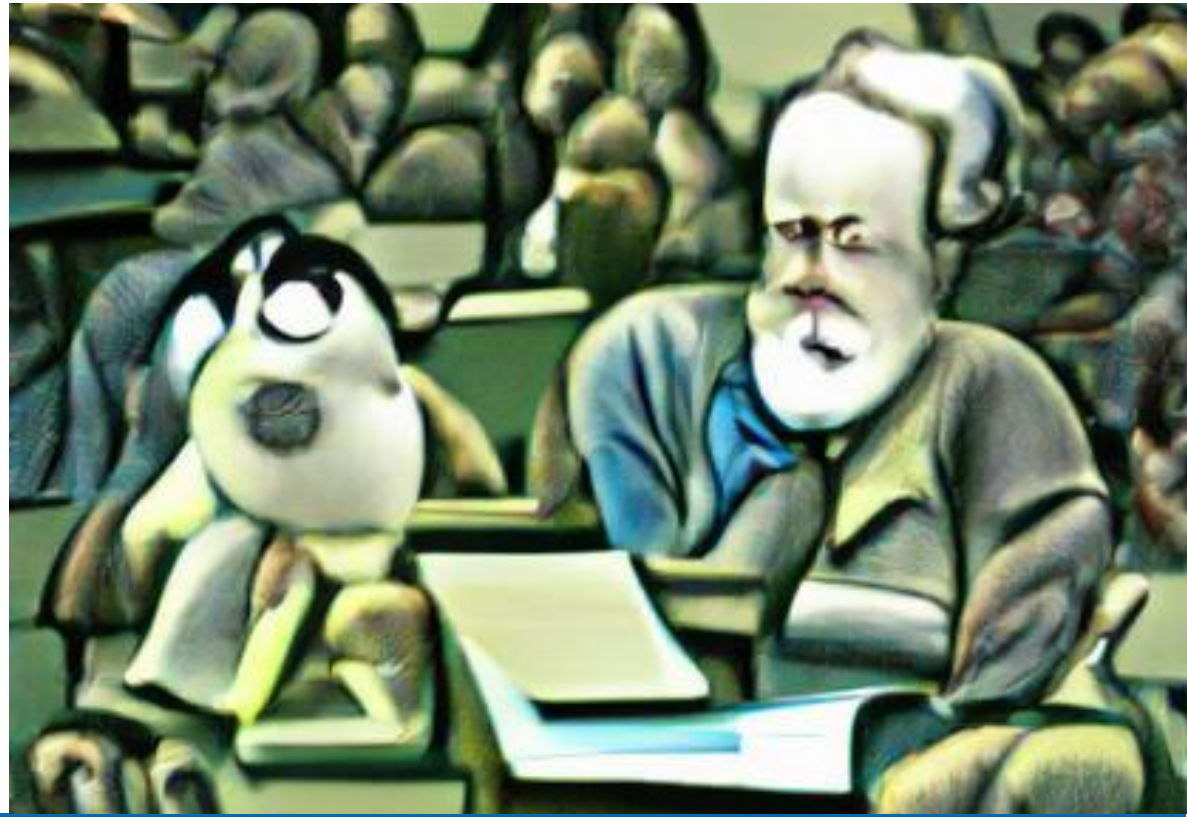
2020-10-23 54.800 € Deichmann

The data controller **denied** the data subject **access to the video** material recorded by **CCTV** in a local store, with which the data subject wanted to prove that he or she had not received any money back after paying in the store. [...]

	Controller	Sector	Country	Fine [€]	Type of Violation	Date
1	Amazon Europe Core S.à.r.l.	Industry and Commerce	LUXEMBOURG	746,000,000	Non-compliance with general data processing principles	16 Jul 2021
2	WhatsApp Ireland Ltd.	Media, Telecoms and Broadcasting	IRELAND	225,000,000	Insufficient fulfilment of information obligations	02 Sep 2021
3	Google LLC	Media, Telecoms and Broadcasting	FRANCE	50,000,000	Insufficient legal basis for data processing	21 Jan 2019
4	H&M Hennes & Mauritz Online Shop A.B. & Co. KG	Employment	GERMANY	35,258,708	Insufficient legal basis for data processing	01 Oct 2020
5	TIM (telecommunications operator)	Media, Telecoms and Broadcasting	ITALY	27,800,000	Insufficient legal basis for data processing	15 Jan 2020
6	British Airways	Transportation and Energy	UNITED KINGDOM	22,046,000	Insufficient technical and organisational measures to ensure information security	16 Oct 2020
7	Marriott International, Inc	Accomodation and Hospitalty	UNITED KINGDOM	20,450,000	Insufficient technical and organisational measures to ensure information security	30 Oct 2020
8	Wind Tre S.p.A.	Media, Telecoms and Broadcasting	ITALY	16,700,000	Insufficient legal basis for data processing	13 Jul 2020
9	Vodafone Italia S.p.A.	Media, Telecoms and Broadcasting	ITALY	12,251,601	Non-compliance with general data processing principles	12 Nov 2020
10	notebooksbilliger.de	Employment	GERMANY	10,400,000	Insufficient legal basis for data processing	08 Jan 2021

enforcementtracker.com, provided by CMS Law.Tax, Creative Commons Attribution-NonCommercial-ShareAlike 4.0 International License.

DSGVO-Vokabeln



“Chip and Chap at statistics lecture, cartoon”

Fachvokabular

Heinrich Heine
Universität Düsseldorf

personenbezogene Daten

alle Informationen, die sich auf eine identifizierte oder **identifizierbare natürliche Person** (im Folgenden „betroffene Person“) beziehen; als identifizierbar wird eine natürliche Person angesehen, die direkt oder indirekt, insbesondere mittels **Zuordnung zu einer Kennung wie** einem Namen, zu einer Kennnummer, zu Standortdaten, zu **einer Online-Kennung** oder zu einem oder mehreren besonderen Merkmalen identifiziert werden kann, die Ausdruck der physischen, physiologischen, genetischen, psychischen, wirtschaftlichen, kulturellen oder sozialen Identität dieser natürlichen Person sind.

Personenbezogene Daten, die anonymisiert, verschlüsselt oder pseudonymisiert wurden, **aber zur erneuten Identifizierung einer Person genutzt werden können, bleiben personenbezogene Daten** und fallen in den Anwendungsbereich der Datenschutz-Grundverordnung.

Fachvokabular

Heinrich Heine
Universität Düsseldorf

Verantwortlicher	die **natürliche oder juristische Person**, Behörde, Einrichtung oder andere Stelle, die allein oder gemeinsam mit anderen **über die Zwecke und Mittel der Verarbeitung von personenbezogenen Daten entscheidet**
Verarbeitung	**jeden** mit oder ohne Hilfe automatisierter Verfahren ausgeführten **Vorgang** oder jede solche Vorgangsreihe **im Zusammenhang mit personenbezogenen Daten** wie das Erheben, das Erfassen, die Organisation, das Ordnen, die Speicherung, die Anpassung oder Veränderung, das Auslesen, das Abfragen, die Verwendung, die Offenlegung durch Übermittlung, Verbreitung oder eine andere Form der Bereitstellung, den Abgleich oder die Verknüpfung, die Einschränkung, das Löschen oder die Vernichtung

Fachvokabular

Heinrich Heine
Universität Düsseldorf

Auftragsverarbeiter	eine **natürliche oder juristische Person**, Behörde, Einrichtung oder andere Stelle, die personenbezogene Daten im Auftrag des Verantwortlichen verarbeitet. Der Auftragsverarbeiter ist an die Weisungen des Verantwortlichen gebunden und dieses **muss** durch einen entsprechenden Vertrag zur Auftrags-verarbeitung (auch **Auftragsverarbeitungsvertrag** = AVV) rechtlich **dokumentiert werden**.
Einwilligung	jede freiwillig für den bestimmten Fall, in informierter Weise und **unmissverständlich abgegebene Willensbekundung** in Form einer Erklärung oder einer sonstigen eindeutigen bestätigenden Handlung, mit der die betroffene Person zu verstehen gibt, dass sie mit der Verarbeitung der sie betreffenden personenbezogenen Daten einverstanden ist.

Mehr Material zur DSGVO-Weiterbildung

Heinrich Heine Universität Düsseldorf

- Datenschutz-Grundverordnung in einfachen Worten
  https://eu-datenschutz-grundverordnung.net/eu-dsgvo/
- DSGVO Volltext: VERORDNUNG (EU) 2016/ 679 DES EUROPÄISCHEN PARLAMENTS UND DES RATES vom 27. April 2016 zum Schutz natürlicher Personen bei der Verarbeitung personenbezogener Daten, zum freien Datenverkehr und zur Aufhebung der Richtlinie 95/46/EG (Datenschutz-Grundverordnung)
  http://eur-lex.europa.eu/legal-content/DE/TXT/PDF/?uri=CELEX:32016R0679
- Checkliste (8 Seiten!) des Bayrischen Landesamts für Datenschutzaufsicht
  https://www.lda.bayern.de/media/checkliste/baylda_checkliste_tom.pdf
- **Filmtipp**: Democracy - Im Rausch der Daten.
  Dokumentation über den Prozess der Entstehung der DSGVO (2015)
  https://www.bpb.de/mediathek/254194/democracy-im-rausch-der-daten

DSGVO vs. USA

& Max Schrems



“Cleaning up a big data mess”

Safe Harbor, Privacy Shield und Max Schrems

Heinrich Heine
Universität Düsseldorf

Entscheidung der Kommission vom 26. Juli **2000** gemäß der Richtlinie 95/46/EG des Europäischen Parlaments und des Rates über die Angemessenheit des von den Grundsätzen des „sicheren Hafens“ und der diesbezüglichen „Häufig gestellten Fragen“ (FAQ) gewährleisteten Schutzes, vorgelegt vom Handelsministerium der USA

Die Safe-Harbor-Entscheidung ist vom Europäischen Gerichtshof (EuGH) durch das Schrems-I-Urteil am 6. Oktober **2015** für ungültig erklärt worden.



Max Schrems (2016), fotografiert von Manfred Werner, CC-BY-SA

Safe Harbor, Privacy Shield und Max Schrems II

Heinrich Heine
Universität Düsseldorf

Durchführungsbeschluss (EU) **2016**/1250 der Kommission vom 12. Juli 2016 gemäß der Richtlinie 95/46/EG des Europäischen Parlaments und des Rates über die Angemessenheit des vom EU-US-Datenschutzschild gebotenen Schutzes

Am 16. Juli **2020** erklärte der EuGH auch den Angemessenheitsbeschluss der EU-Kommission über das EU-US Privacy Shield durch das Schrems-II-Urteil für ungültig.



Max Schrems (2016), fotografiert von Manfred Werner, CC-BY-SA

Safe Harbor, Privacy Shield und Max Schrems III?

Heinrich Heine
Universität Düsseldorf

Datenschutzrechtlich Verantwortliche können sich nun nicht mehr länger bei Datentransfers zu Verantwortlichen oder Auftragsverarbeitern mit Sitz in den Vereinigten Staaten, die sich selbst nach dem EU-US Privacy Shield zertifiziert haben, auf die Angemessenheit des Datenschutzniveaus gem. Art. 45 DSGVO berufen.

Der Datenschutzaktivist Max Schrems hat mit seiner NGO noyb (“none of your business”) Beschwerde gegen 101 europäische Unternehmen erhoben.

Er wirft ihnen vor, ihre Websites immer noch unter Verwendung von Google Analytics und Facebook Connect zu betreiben.
Das ist laut einer Entscheidung des Europäischen Gerichtshof jedoch nicht mehr rechtskonform.



Max Schrems (2016), fotografiert von Manfred Werner, CC-BY-SA

Ende März 2022: Agreement in principle?



Ursula von der Leyen
@vonderleyen

Pleased that we found an agreement in principle on a new framework for transatlantic data flows.

It will enable predictable and trustworthy 🇪🇺🇺🇸 data flows, balancing security, the right to privacy and data protection.

This is another step in strengthening our partnership.

10:22 AM · Mar 25, 2022 · Twitter for iPhone

460 Retweets **253** Quote Tweets **1,196** Likes

The show must go on …

- The EU-U.S. **Data Privacy Framework** (DPF), formally Commission Implementing Decision (EU) 2023/1795, has formed the legal basis for many transatlantic transfers **since July 2023**. More than 5,300 U.S. organisations have self-certified under the Framework [...].
- In Trump v. Slaughter (No. 25-332), the U.S. Supreme Court ruled on 29 **June 2026**, by a majority of 6 to 3, that statutory restrictions on the President's power to remove Commissioners of the **Federal Trade Commission** (FTC) are contrary to the Constitution of the United States. [...] Within the **DPF**, the **FTC** is not the only actor, but it is a central one. [...] Article 8(3) of the Charter of Fundamental Rights of the European Union [...] requires that compliance with data protection rules be subject to control by an independent authority.
- noyb has announced that it is preparing a legal challenge to the **DPF** before the Court of Justice of the European Union (CJEU).

(2.7.2026, activemind.legal Yalcin Erleblebici "EU-U.S. Data Privacy Framework at risk following U.S. Supreme Court ruling" www.activemind.legal/guides/dpf-supreme-court/)

Ein neues Buch über ethical data science

Alfred Spector, Peter Norvig, Chris Wiggins, Jeannette M. Wing:
Data Science in Context: Foundations, Challenges, Opportunities
(23.5.2022, Cambridge University Press)



Figure I.5 Ethics Flow Throughout the Book

Das Buch enthält Data Science ohne Formeln, ohne Code, das aber sehr, sehr gut.

Danke für Ihre Aufmerksamkeit.